

Höldum áfram og förum í næsta skref: "Technical Specification v0.4 — Workflow & Security Model".

Já. Nú skilgreinum við **workflow-state vélina og security model** þannig að v0.5 geti byggt á skýrum reglum í stað þess að þurfa að giska á þær.

Technical Specification v0.4

Workflow & Security Model

Project: Icelandic Legal Case Management System — ILCMS

Version: 0.4

Status: Technical Design Draft

Scope: Case lifecycle, document lifecycle, evidence, court filings, approvals, legal holds, retention, RBAC/ACL og audit.

1. Grundvallarregla

Kerfið skal aðgreina þrjú hugtök:

WHO?

↓

Identity / User

WHAT CAN THEY DO?

↓

Role + Permission

ON WHICH CASE / RESOURCE?

↓

Case Access Control

Þannig er ekki nóg að segja:

„User X er Lawyer.“

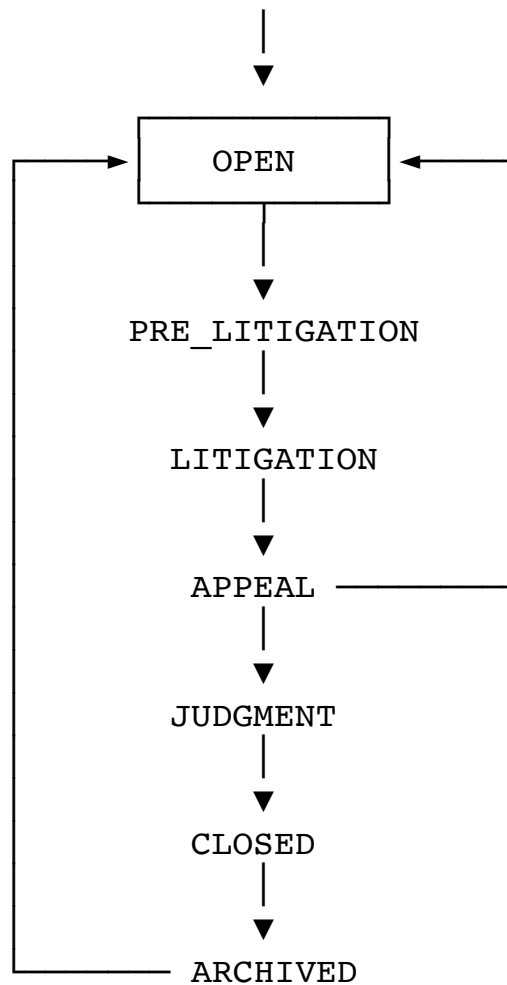
Við þurfum líka að vita:

„Má Lawyer X lesa þetta tiltekna mál og má hann framkvæma þessa tilteknu aðgerð?“

2. Case lifecycle

Ég legg til eftirfarandi state machine:





ON_HOLD getur komið inn frá flestum virkum stöðum.

3. Case states

State	Meaning
NEW	Mál nýskráð
OPEN	Virkt mál
ON_HOLD	Málsmeðferð tímabundið stöðvuð
PRE_LITIGATION	Undirbúningur fyrir málarekstur
LITIGATION	Virkt dómsmál
APPEAL	Áfrýjun
JUDGMENT	Dómur/úrskurður kominn
CLOSED	Máli lokið
ARCHIVED	Lokið og varðveitt samkvæmt retention policy

4. Allowed Case transitions

Ég myndi gera transitions explicit:

NEW

└─ OPEN

OPEN

├─ ON_HOLD
├─ PRE_LITIGATION
├─ LITIGATION
└─ CLOSED

ON_HOLD

└─ OPEN

PRE_LITIGATION

├─ LITIGATION
├─ ON_HOLD
└─ CLOSED

LITIGATION

├─ APPEAL
├─ JUDGMENT
└─ ON_HOLD

APPEAL

├─ JUDGMENT
└─ ON_HOLD

JUDGMENT

└─ CLOSED

CLOSED

└─ ARCHIVED

Ekki leyfa:

ARCHIVED → OPEN

nema með sérstöku administrative/legal workflow.

5. Case transition API

Ekki:

```
PATCH /cases/{id}
{
  "status": "CLOSED"
```

```
}
heldur:

POST /api/v1/cases/{id}/transitions
{
  "transition": "CLOSE",
  "reason": "Máli lokið samkvæmt samkomulagi aðila."
}
Þetta gefur okkur:
```

- validation
- authorization
- audit
- reason
- workflow enforcement.

6. Case transition history

Ég myndi bæta við:

```
case_status_history
id
case_id
from_status
to_status
reason
performed_by
performed_at
Þannig getum við séð:
```

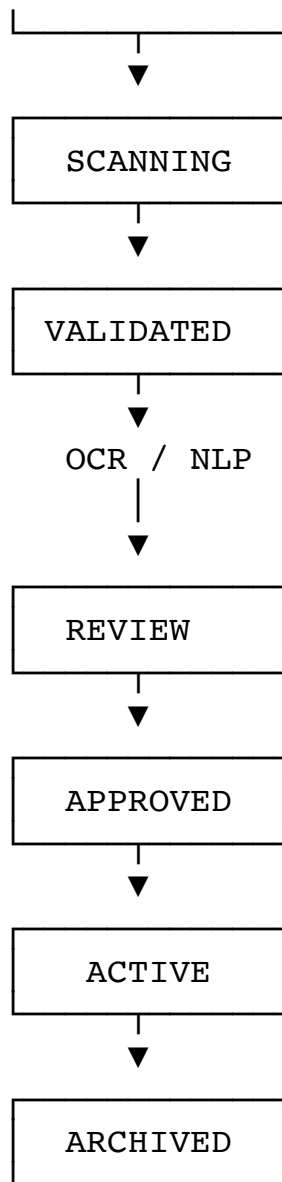
```
01 Sep 2026 10:15 NEW → OPEN
02 Sep 2026 14:20 OPEN → PRE_LITIGATION
17 Sep 2026 09:10 PRE_LITIGATION → LITIGATION
...
```

Þetta er mikilvægt fyrir auditability.

7. Document lifecycle

Skjal hefur annan lifecycle:

UPLOADED



8. Document states

UPLOADED
SCANNING
QUARANTINED
VALIDATED
PROCESSING
REVIEW
APPROVED
ACTIVE
REJECTED
ARCHIVED

Sérstaklega mikilvægt

QUARANTINED þýðir að skjalið má **ekki** verða sýnilegt venjulegum notendum.

Dæmi:

Upload

↓

Malware detected

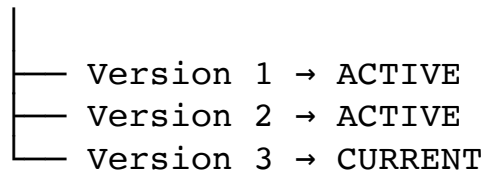
↓

QUARANTINED

9. Document versioning

Document og document version eru tvö mismunandi lifecycle.

DOCUMENT



Original version verður immutable.

Enginn:

PUT /documents/{id}/versions/1

Leyfilegur.

Ný breyting = ný version.

10. Evidence lifecycle

Sönnunargögn þurfa strangari stjórn:

IDENTIFIED

↓

COLLECTED

↓

REGISTERED

↓

VERIFIED

↓

IN_CUSTODY

↓

PRESENTED

↓

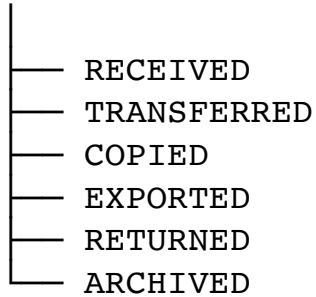
RETURNED / ARCHIVED

Ekki má eyða evidence object þó skjalinu sjálfu hafi verið breytt eða ný útgáfa búin til.

11. Chain of custody

Öll custody activity:

Evidence



skal vera append-only.

Dæmi:

Evidence E-1001

09:12 RECEIVED
User: A

11:30 TRANSFERRED
A → B

14:42 COPIED
B

16:15 EXPORTED
B → Court

12. Court filing workflow

Þetta verður sérstaklega mikilvægt:

DRAFT



INTERNAL_REVIEW



APPROVED



READY_FOR_SUBMISSION



SUBMITTED



RECEIVED

↓

FILED

Error paths:

INTERNAL_REVIEW

↓

REJECTED

↓

DRAFT

og:

SUBMITTED

↓

REJECTED_BY_COURT

↓

DRAFT

13. Court filing approval

Reglan ætti að vera:

AUTHOR

↓

REVIEWER

↓

APPROVER

↓

SUBMISSION

Ekki leyfa sama user að gera allt í sensitive workflow nema sérstaklega heimilað.

Þetta kallast í reynd **separation of duties**.

14. Approval model

Generic approval model:

approval_requests

Með:

id

case_id

resource_type

resource_id

requested_by

requested_at

approved_by
approved_at
rejected_by
rejected_at
status
comments
Status:

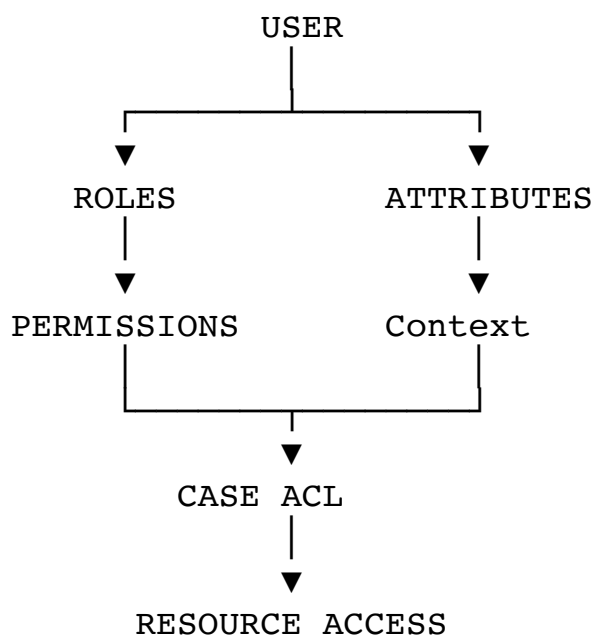
PENDING
APPROVED
REJECTED
CANCELLED

Petta gerir approval reusable fyrir:

- court filings
- sensitive document exports
- case closure
- legal hold release
- retention deletion.

15. Security architecture

Ég legg til **RBAC + ABAC-lite + ACL**.



16. RBAC

Role dæmi:

SYSTEM_ADMIN

CASE_MANAGER

LAWYER

PARALEGAL

REVIEWER

EXTERNAL_COUNSEL

READ_ONLY

AUDITOR

En role gefur aðeins **candidate permissions**.

17. Permissions

Permission er:

RESOURCE + ACTION

Dæmi:

CASE:READ

CASE:CREATE

CASE:UPDATE

CASE:CLOSE

DOCUMENT:READ

DOCUMENT:CREATE

DOCUMENT:UPDATE

DOCUMENT:DOWNLOAD

DOCUMENT:EXPORT

EVIDENCE:READ

EVIDENCE:TRANSFER

FILING:CREATE

FILING:APPROVE

FILING:SUBMIT

AUDIT:READ

18. Case-level ACL

Dæmi:

Case LGM-2026-00123

User A
READ
WRITE
EXPORT

User B
READ
WRITE

User C
READ

External Counsel
READ

Þetta er geymt í:

case_permissions

19. Confidentiality levels

Ég myndi hafa:

PUBLIC
INTERNAL
CONFIDENTIAL
HIGHLY_CONFIDENTIAL
PRIVILEGED
og resource inheritance:

CASE
↓
DOCUMENT
↓
DOCUMENT VERSION
↓
EVIDENCE
Default:

Resource má ekki verða **minna confidential** en parent resource nema með explicit authorization.

Dæmi:

Case = CONFIDENTIAL

Document = PUBLIC
→ **BLOCKED**

20. Legal privilege

`legal_privilege` þarf að vera sérstök security dimension.

Dæmi:

DOCUMENT

```
| confidentiality = HIGHLY_CONFIDENTIAL  
| legal_privilege = TRUE
```

Aðgangur að slíku skjali ætti að krefjast bæði:

CASE ACCESS

+

PRIVILEGED DOCUMENT ACCESS

21. Attribute-based rules

Síðar getum við haft reglur eins og:

```
IF user.organization != case.organization  
THEN deny
```

eða:

```
IF document.legal_privilege = TRUE  
AND user.role NOT IN (...)  
THEN deny
```

eða:

```
IF case.status = ARCHIVED  
AND user.role != SYSTEM_ADMIN  
THEN read-only
```

22. Access decision model

Ég myndi skilgreina þetta formlega:

```
ALLOW =  
    authenticated  
    AND role_permission  
    AND case_access  
    AND confidentiality_access  
    AND resource_state_allows  
    AND legal_hold_rules_allow
```

Allar fimm þurfa að standast.

23. Read vs Download vs Export

Þetta ætti að vera **þrjár mismunandi permissions**.

DOCUMENT:READ

DOCUMENT:DOWNLOAD

DOCUMENT:EXPORT

Dæmi:

Lawyer

READ ✓

DOWNLOAD ✓

EXPORT ✓

Reviewer

READ ✓

DOWNLOAD ✓

EXPORT ✗

External Counsel

READ ✓

DOWNLOAD ✓

EXPORT ✗

24. Audit requirements

Við ætlum að audit-a ekki bara breytingar heldur einnig mikilvæga lesaðgerð.

Must audit

LOGIN

LOGOUT

CASE_CREATE

CASE_UPDATE

CASE_STATUS_CHANGE

CASE_CLOSE

DOCUMENT_CREATE

DOCUMENT_VIEW

DOCUMENT_DOWNLOAD

DOCUMENT_EXPORT

DOCUMENT_VERSION_CREATE

EVIDENCE_CREATE
EVIDENCE_VIEW
EVIDENCE_TRANSFER

FILING_CREATE
FILING_APPROVE
FILING_SUBMIT

PERMISSION_GRANT
PERMISSION_REVOKE

LEGAL_HOLD_CREATE
LEGAL_HOLD_RELEASE

RETENTION_DELETE

25. Audit immutability

Application user má **aldrei** gera:

UPDATE audit_log ...
DELETE FROM audit_log ...

Ég myndi jafnvel nota PostgreSQL role separation:

application_user

↓

NO DELETE on audit_log
NO UPDATE on audit_log
og sérstakan:

audit_writer
fyrir INSERT.

26. Legal Hold workflow

REQUESTED

↓

APPROVED

↓

ACTIVE

↓

RELEASE_REQUESTED

↓

RELEASED

Regla:

ACTIVE



Retention deletion = BLOCKED

og:

RELEASED



Retention engine may evaluate resources

27. Retention workflow

Ekki:

retention_date reached



DELETE

heldur:

Retention period reached



Candidate for disposal



Check legal hold



Check active proceedings



Check preservation requirement



Human approval



DISPOSAL

28. Disposal

Ég myndi hafa:

retention_candidates

og:

disposal_requests

Pannig verður eyðing sjálf workflow:

SYSTEM



Candidate



Reviewer



Approver



Disposal

29. Soft delete

Almennt:

deleted_at

deleted_by

frekar en physical DELETE.

En fyrir skjöl þarf aðgreina:

logical deletion

frá:

physical destruction

þar sem retention policy ræður því hvenær binary má raunverulega eyða.

30. Document export security

Export ætti að vera sérstök aðgerð:

EXPORT REQUEST



Authorization



Optional approval



Generate package



Hash package



Audit



Temporary download

Package getur innihaldið:

manifest.json

documents/

metadata/
audit-summary/

31. Secure document package

Dæmi:

CASE-2026-00123-export.zip

```
manifest.json
├── document_id
├── version
├── filename
├── sha256
└── exported_at
```

```
documents/
├── DOC-001.pdf
├── DOC-002.pdf
└── DOC-003.pdf
```

Petta er mjög gagnlegt fyrir court submission, external counsel og discovery/eDiscovery.

32. Notifications

Workflow events geta framkallað notifications:

Deadline approaching

↓

Notification

Document requires review

↓

Notification

Court filing approved

↓

Notification

Legal hold released

↓

Notification

En notification má **ekki** innihalda viðkvæmt skjalainnihald nema sérstaklega heimilað.

Betra:

"Document DOC-123 requires review."
en:

"Here is the confidential legal document..."

33. Background jobs

Workflow engine mun senda events:

DocumentUploaded
DocumentValidated
DocumentApproved

DeadlineCreated
DeadlineApproaching

FilingApproved
FilingSubmitted

LegalHoldCreated
LegalHoldReleased
Sem fara í:

Outbox
↓
Message / Job Worker

34. Security event flow

Dæmi:

User requests document

↓
Authentication
↓
Authorization
↓
Case ACL
↓
Confidentiality
↓
Privilege
↓

Document state



ALLOW



Audit VIEW



Return document

Þetta ætti að vera **central policy**, ekki endurtekið handvirkt í hverjum API endpoint.

35. Zero-trust principle

Kerfið á ekki að gera ráð fyrir:

"User is a lawyer → trusted"
heldur:

Every request



Authenticate



Authorize



Verify resource access

Þetta verður sérstaklega mikilvægt ef við bætum síðar við:

- mobile clients
- external counsel
- integrations
- AI services
- automated agents.

36. AI Security Boundary

Þetta er atriði sem ég myndi setja inn **nú þegar**, jafnvel þótt AI verði ekki í MVP.

AI service á **ekki** að fá:

database credentials
og ekki:

unrestricted access to all cases
heldur:

User

↓

AI API

↓

Authorization

↓

Case-scoped retrieval

↓

Approved documents only

↓

LLM

Dæmi:

LAWYER A asks AI:

"Summarize this case."

AI

↓

Can access only:

CASE-00123

↓

Documents permitted to Lawyer A

Þetta kemur í veg fyrir mjög alvarlegt **cross-case data leakage**.

37. AI audit

Allar AI aðgerðir ættu síðar að vera audit-aðar:

AI_REQUEST

AI_DOCUMENTS_RETRIEVED

AI_RESPONSE_GENERATED

AI_EXPORT

og geyma:

user

case

timestamp

model

documents used

prompt classification

Ekki endilega geyma hráa promptinn að eilífu; það þarf að meta það út frá privacy/retention requirements.

38. Separation of duties

Fyrir sensitive actions:

Action	Creator	Reviewer	Approver
Case	✓		
Sensitive document	✓	✓	
Court filing	✓	✓	✓
Legal hold	✓		✓
Legal hold release		✓	✓
Case closure	✓	✓	✓
Destruction		✓	✓

Að minnsta kosti fyrir high-risk workflows ætti sama user ekki að geta bæði **create + approve**.

39. Security matrix

Grunnmatrix:

Role	Case	Documents	Evidence	Filing	Audit
System Admin	Admin	Admin	Admin	Admin	Read
Lawyer	RW	RW	RW	Create/Approve*	Own cases
Case Manager	RW	RW	R	Create	Limited
Paralegal	RW	RW	R	Create	No
Reviewer	R	R	R	Review	No
External Counsel	R	R*	R*	Submit*	No
Read Only	R	R	R	No	No
Auditor	R	R	R	R	Read

* case-specific authorization required.

40. Security invariants

Þetta eru reglur sem eiga að vera ófrávíkjanlegar:

S1

No authentication → No protected resource access

S2

No case access → No case resource access

S3

No permission → No action

S4

Original document version is immutable

S5

Audit records are immutable

S6

Active legal hold blocks destruction

S7

Archived case is read-only by default

S8

Confidentiality cannot be bypassed through API

S9

AI services receive only explicitly authorized data

S10

Sensitive workflow requires appropriate separation of duties

41. Nýjar töflur eftir v0.4

Við þurfum nú að bæta eftirfarandi við v0.3 schema:

case_status_history
approval_requests
retention_candidates
disposal_requests
og líklega:

document_status_history
filing_status_history

Ég myndi hafa history sérstaklega fyrir workflow objects fremur en treysta eingöngu á audit_log.

Pá verður greinarmunurinn:

AUDIT LOG

= Who did what?

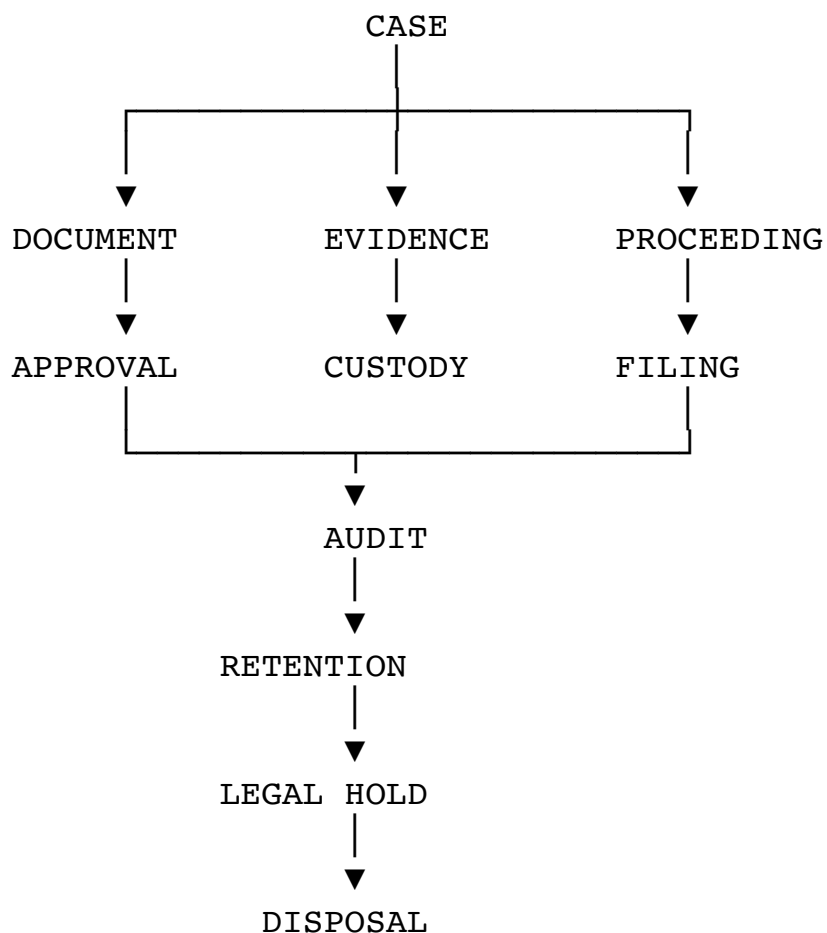
STATUS HISTORY

= What was the lifecycle of this object?

Þetta er mjög gagnleg aðgreining.

42. Endanlegt workflow model

Í heild:



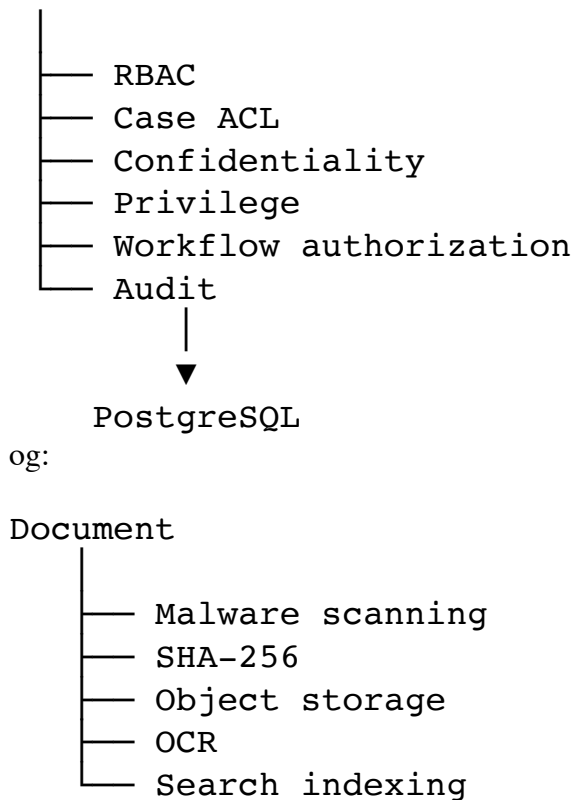
43. Mínimum security architecture

Fyrsta production útgáfan ætti því að hafa:

OIDC



API Gateway / Application



44. Staðan eftir v0.4

Við höfum nú skilgreint fjögur lög:

v0.1

Concept / Requirements

v0.2

Data Model

v0.3

PostgreSQL + REST API

v0.4

Workflow + Security

Þetta er nú orðið nógu nákvæmt til að fara yfir í **raunverulega implementation specification**.

Næsta skref — Technical Specification v0.5

Ég myndi gera v0.5 sem **Production PostgreSQL Schema & Migrations**, ekki bara lista yfir töflur.

Það myndi innihalda:

1. Fullt **001_initial_schema.sql**
2. Allar ~30 töflurnar með PK/FK

3. Indexes
4. Check constraints
5. Unique constraints
6. `updated_at` triggers
7. Audit triggers
8. Append-only enforcement
9. Case-status state machine
10. Document state machine
11. Seed data fyrir roles/permissions
12. PostgreSQL roles fyrir application/audit/read-only access
13. Migration strategy
14. Backup/restore considerations
15. Test data
16. **Database ER diagram**

Þá getum við í raun tekið v0.5 og byrjað að byggja **fyrstu PostgreSQL migrationuna** beint út frá specification-inu.